Information e-commerce et données - audit de MiniShop

Recherche et audit du code au **23 octobre 2026**, France, vente de biens à des consommateurs. Document de travail pédagogique, **pas un avis juridique ni une certification de conformité**. Le droit évolue : vérifier les textes, le modèle économique et les informations effectives avec le professionnel avant une mise en ligne commerciale. Les obligations concernent avant tout des **informations et des fonctions** ; toutes n'imposent pas nécessairement une page autonome portant un nom particulier.

1. Sources et structure retenue

Sujet	Source de référence	Traduction dans la maquette
Identification et informations précontractuelles	[Service public : mentions d'un site professionnel](https://entreprendre.service-public.gouv.fr/vosdroits/F37351), [DGCCRF : e-commerce](https://www.economie.gouv.fr/dgccrf/les-fiches-pratiques/e-commerce-les-regles-entre-professionnels-et-consommateurs)	`/mentions-legales` (édition étudiante non professionnelle : Johan Polsinelli et Chahd Gouiaa, co-direction de publication, e-mails universitaires selon art. 6-III-2 LCEN, hébergement pédagogique visé Université Côte d'Azur - IUT Nice Côte d'Azur), `/cgv`, total et frais simulés avant confirmation ; aucun vendeur commercial identifié.
Livraison et retours	[DGCCRF : achat en ligne](https://www.economie.gouv.fr/dgccrf/les-fiches-pratiques/comment-realiser-des-achats-sur-internet-de-facon-securisee)	`/livraison` et `/retractation` ; aucun délai ou transporteur inventé.
Rétractation	[L. 221-21](https://www.legifrance.gouv.fr/codes/article_lc/LEGIARTI000044563193), [D. 221-5](https://www.legifrance.gouv.fr/codes/article_lc/LEGIARTI000053303365), [modèle R. 221-1](https://www.legifrance.gouv.fr/codes/article_lc/LEGIARTI000045418600), [avis type R. 221-3](https://www.legifrance.gouv.fr/codes/article_lc/LEGIARTI000053303407), [Service public](https://www.service-public.fr/particuliers/vosdroits/F10485)	Délai en principe de 14 jours dès réception pour les biens, exceptions ; modèle de rétractation, distinct de l'annulation de la commande. **Fonction en ligne absente**, voir §3.
Garanties légales	[D. 211-2](https://www.legifrance.gouv.fr/codes/article_lc/LEGIARTI000045987267), [annexe D. 211-2, partie A](https://www.legifrance.gouv.fr/codes/article_lc/LEGIARTI000045981314)	Encadré réglementaire reproduit dans les CGV et sur `/garanties`. Professionnel répondant des garanties et ses coordonnées à compléter.
Médiation	[DGCCRF : médiation de la consommation](https://www.economie.gouv.fr/dgccrf/les-fiches-pratiques/la-mediation-de-la-consommation-ce-que-vous-devez-savoir)	Nom, adresse et site du médiateur réellement désigné à compléter ; réclamation préalable. Aucun médiateur fictif.

Données personnelles	[RGPD chapitre III](https://www.cnil.fr/fr/reglement-europeen-protection-donnees/chapitre3), [CNIL : transparence](https://www.cnil.fr/fr/conformite-rgpd-information-des-personnes-et-transparence), [CNIL : durées](https://www.cnil.fr/fr/passer-laction/les-durees-de-conservation-des-donnees)	`/confidentialite` décrit les traitements observés et ce qui reste à déterminer, plutôt que des promesses de purge.
Cookies	[CNIL : lignes directrices et recommandation](https://www.cnil.fr/fr/cookies-et-autres-traceurs/regles/cookies/lignes-directrices-modificatives-et-recommandation), [mise en conformité](https://www.cnil.fr/fr/cookies-et-autres-traceurs/regles/cookies/comment-mettre-mon-site-web-en-conformite), [FAQ](https://www.cnil.fr/fr/cookies-et-autres-traceurs/regles/cookies/FAQ)	`/cookies` ; absence de bandeau fictif pour les seuls traceurs nécessaires observés ; examen complémentaire si ajout de traceurs ou service tiers.

Comparaison sans copie de clauses : [Boulanger : CGV](https://www.boulanger.com/evenement/conditions-generales-vente-boulanger) et [mentions légales](https://www.boulanger.com/evenement/infos-legales) séparent notamment vente, informations d'identification et livraison. [Fnac Marketplace](https://www.fnac.com/Help/cgv-fnac-marketplace) et [Back Market](https://www.backmarket.fr/fr-fr/legal/terms-of-use) distinguent aussi plateforme et vendeurs tiers. MiniShop n'étant pas une place de marché, les obligations propres à l'intermédiation ne sont pas importées par simple analogie. L'étude de **présentation** et ses principes responsive précèdent le CSS dans `docs/DA.md` §12. `/cgu` est une page de confort, pas une affirmation qu'une page CGU séparée serait systématiquement obligatoire.

2. Audit des données et des cookies

• `app/Security/Auth.php` démarre `MINISHOPSESS` pour la session (panier, connexion, jeton CSRF) : `HttpOnly`, `SameSite=Lax`, `Secure` seulement si PHP détecte HTTPS. Les autres paramètres et durées viennent de PHP et du navigateur. Le mode WASM possède une implémentation de session propre au harnais ; ses résultats ne valent pas validation du serveur PHP natif derrière un proxy.

• `public/mesurer.php` crée un autre cookie de session `MINISHOPSESSID`, `HttpOnly`, `SameSite=Lax`, durée session, **`Secure=false`**. Outil de développement, non nécessaire à la boutique. Son garde dépend notamment du nom d'hôte ou d'indices locaux : ne pas le considérer comme une barrière de sécurité suffisante. **Exclure `mesurer.php` et `gen_volumes.php` du déploiement public**, vérifier les autres outils de développement et supprimer les marqueurs de déverrouillage.

• Inspection des scripts et vues applicatifs : pas de pixel marketing, SDK analytics, `document.cookie` ou `sessionStorage` identifié. `public/js/preferences.js` utilise `localStorage` (`minishop.preferences.v1`) uniquement pour la langue et le fuseau horaire lorsque l'utilisateur enregistre ses

préférences, et peut appeler `navigator.geolocation.getCurrentPosition` après clic explicite pour déduire localement le fuseau via `tz-lookup.js` sans transmettre ni conserver les coordonnées ; le JavaScript du panier et du tableau de bord admin fait uniquement des requêtes vers l'origine. La CSP du contrôleur frontal autorise des ressources locales. Ce constat porte sur le dépôt et les parcours testés, **pas** sur une future intégration, une extension navigateur, les services internes de localisation du navigateur/OS, le serveur web, un proxy ou les éventuels services de l'hébergeur. Refaire l'inventaire réseau/stockage sur l'instance réelle.

• Le cookie de session servant au panier, à l'authentification et à la sécurité, ainsi que le stockage local limité au choix de langue/fuseau demandé par l'utilisateur, sont susceptibles d'être exemptés de consentement sous les conditions CNIL, avec information transparente dans `/cookies` et `/confidentialite`. Aucun choix « tout accepter / refuser » n'est simulé. Si un traceur non exempté est ajouté : information préalable complète, consentement positif avant dépôt, refus aussi simple, retrait à tout moment, preuve et contrôle des tiers ; l'exemption de mesure d'audience n'est jamais automatique.

• Comptes, coordonnées et commandes sont stockés en JSON ou SQL. En mode JSON, les fichiers `data/minishop/*.json` versionnés servent de jeu d'essai de démonstration et sont créés/mis à jour en clair hors chiffrement applicatif ; en cas d'erreur pendant un commit multi-fichiers JSON, une écriture partielle reste possible (`app/View/errors/500.php` n'affirme plus qu'aucune donnée n'a été modifiée). Le journal du moteur JSON `var/journal/db.jsonl` minimise désormais les nouvelles entrées `client` et `administrateur` (sans nom, e-mail ni condensat `mot_de_passe_hash`), mais les commandes, le nom d'acteur administrateur et les entrées historiques peuvent encore contenir des données personnelles. Le contact écrit nom, e-mail, message et date dans `var/log/contact.jsonl`, sans envoi d'e-mail ; les anciennes entrées sont limitées à 500 caractères, les nouvelles sont complètes jusqu'à 2 000 caractères. L'échec d'écriture est signalé ; aucun délai de réponse n'est garanti. Les nouveaux fichiers contact et journaux passent par `NettoyageJournaux::ajouter` avec un masque restrictif et un `chmod` 0600 si possible, mais **cela ne constitue pas un audit de sécurité ni ne corrige les permissions des tables JSON ou des autres journaux serveur**.

• `conservation_compte=24` est la valeur initiale du seed pour les comptes inactifs sans commande, appliquée uniquement si l'exploitant exécute `scripts/purger_comptes.php` ou la maintenance CLI dédiée. Des rotations manuelles séparées (simulées par défaut, non planifiées) existent pour `contact.jsonl` (12 mois), le journal JSON (6 mois) et un dossier local dédié de sauvegardes (30 jours), ainsi qu'un outil manuel de copies chiffrées (`scripts/archive_restreinte.php`) qui ne retire pas la donnée source. Les comptes ayant des commandes, les sessions, les copies d'hébergement et les archives légales nécessitent encore des règles, habilitations et procédures effectives et testées. Le serveur et l'hébergeur peuvent produire d'autres journaux ; accès, sous-traitants, localisation et transferts sont inconnus.

3. Points bloquants avant de vendre réellement

• [!] Identifier et publier un vendeur professionnel avant toute exploitation commerciale : dénomination, forme sociale, capital le cas échéant, adresse professionnelle, e-mail et téléphone effectifs, immatriculation RCS/RNE et TVA intracommunautaire, responsable de publication commercial et hébergeur effectif de production (les mentions actuelles ne couvrent

que l'édition étudiante non professionnelle et l'hébergement pédagogique visé). Déterminer les mentions supplémentaires liées au statut et aux produits.

• [!] Finaliser les CGV avec le professionnel : moyens de paiement effectifs, conditions et restriction de livraison, délais ou dates, prix et frais, destinataire et frais de retour, traitement des réclamations, coordonnées du vendeur responsable des garanties, médiateur désigné avec adresse et site. Vérifier toutes les informations produit et environnementales applicables aux catégories vendues, et les modalités d'archivage contractuel.

• [!] Depuis le **19 juin 2026**, pour les contrats concernés conclus en ligne, L. 221-21 et D. 221-5 exigent une fonctionnalité gratuite, visible, directe et facile d'accès, qui permette la déclaration (nom/prénom, détails du contrat et moyen électronique de réception), une étape explicite « confirmer la rétractation » ou équivalent et un accusé de réception sur support durable mentionnant contenu, date et heure d'envoi dans un délai raisonnable. La disponibilité vaut pendant le délai légal. Le professionnel doit prévoir réception effective, traçabilité et traitement fiable ; accès non conditionné à une connexion si cela rend l'exercice inaccessible. **C ette fonction n'existe pas dans MiniShop.** Une page statique, une annulation avant expédition, un téléchargement local ou le contact de démonstration ne la remplacent pas. Avant ouverture commerciale : concevoir la réception et la confirmation, un canal d'envoi fiable, la gestion des pannes/reprises et des données, puis tester sécurité, accessibilité et conservation de la preuve ; faire valider juridiquement l'ensemble.

• [!] Le bouton actuel et le statut « payée » sont des **simulations**. En vente réelle, vérifier l'obligation de paiement clairement indiquée sur le bouton, la possibilité de corriger la commande avant validation, la preuve de commande et sa confirmation sur support durable, ainsi que l'application des CGV et des droits du consommateur. Aucun paiement réel, expédition, remboursement, SAV ou notification e-mail n'est implémenté par cette passe.

• [!] Désigner le responsable du traitement, le cas échéant son représentant ou DPO, publier ses coordonnées et celles pour exercer les droits, les finalités et bases adaptées, destinataires/sous-traitants, durées ou critères, transferts et garanties ; mettre en place les réponses aux demandes et la procédure de réclamation CNIL. Définir les règles et automatiser la suppression/anonymisation applicables à chaque stockage, y compris sessions, audit, contact et sauvegardes. Examiner la minimisation des anciennes/nouvelles valeurs du journal.

• [!] Vérifier sur l'hébergement réel : TLS et `Secure` derrière proxy de confiance, accès stricts aux fichiers hors `public/`, permissions, chiffrement et sauvegardes, journaux serveur, authentification d'administration et supervision. Désactiver les outils de développement ; ne pas utiliser de données réelles tant que l'ensemble n'est pas prêt.

• [!] Vérifier les exigences d'accessibilité applicables au service et les éventuelles exemptions ; réaliser un audit manuel avec technologies d'assistance, tailles de viewport et navigateur réel. La présence de tests et de CSS responsive ne prouve pas une conformité WCAG/RGAA complète.

4. Vérification et auto-évaluation

• `tests/php/information_juridique_test.php` vérifie routes et liens du pied, éléments essentiels des textes, absence de promesses trompeuses, lien formulaire et commande, et présence du CSS centré. Ce sont des **contrats de régression**, pas une preuve que le droit est

respecté.

• Le parcours HTTP WASM vérifie l'accès public aux huit pages, rendu de l'encadré, modèle et réserve de rétractation, cookie observé, formulaire de contact valide, CSRF, échappement XSS et échec d'écriture. Les journaux du test restent isolés et ne remplacent pas ceux de l'utilisateur.

• Tests responsive statiques et suite applicative complète : voir `docs/10-todo-corrections.md` pour les résultats datés. [!] Aucun contrôle visuel navigateur complet ni test SQL réel dans cette sandbox.

• **Bilan :** information plus claire, structurée et traçable pour la soutenance ; **non prêt pour une boutique réelle** tant que les blocages précédents et une validation juridique ne sont pas levés. Un contenu légal, même exact à une date donnée, ne remplace jamais les services et processus réels.